

איסוף מידע

מודול 4 — Reconnaissance

- ◀ פסיבי מול אקטיבי
- ◀ אימות היעד וגבולות ההרשאה (Scope)
- ◀ OSINT: מיילים, אנשים, דלף מידע
- ◀ תת-דומיינים, טכנולוגיות, Burp, Google Dorking

פסיבי מול אקטיבי

- ◀ **פסיבי (Passive)** — ללא מגע ישיר; גוגל, LinkedIn, דלף מידע
- ◀ **אקטיבי (Active)** — מגע ישיר; סריקה, חיבור לשרת
- ◀ תמיד מתחילים בפסיבי — שקט, ללא עקבות
- ◀ 🔍 שלב אקטיבי מלא = מודול 5

אימות היעד ו-Scope

◀ ודא שאתה תוקף את היעד הנכון — טעות = עבירה

◀ In-Scope — מותר לתקוף

◀ Out-of-Scope — אסור במפורש

◀ RoE — כללי ההתקשרות

◀ קרא את ה-Scope בכל פעם מחדש ⚠

OSINT: מיילים ואנשים

- ◀ מטרה: לגלות את **תבנית המייל** של הארגון
- ◀ **hunter.io** — מיילים לפי דומיין
- ◀ **clearbit** — תוסף Gmail, שמות ותפקידים
- ◀ **phonebook.cz, voilanorbert**

אימות מייל

◀ **emailhippo / email-checker** — האם המייל תקין

◀ **HavelBeenPwned** — האם הופיע בדלף מידע

◀ **"שכחתי סיסמה"** — מאשר קיום חשבון

◀  משלבים מספר מקורות, לא כלי אחד

דלף מידע (Data Breaches)

- ◀ מקור יעיל לפרטי גישה (Credentials)
- ◀ פריצות: LinkedIn, Equifax, Home Depot
- ◀ כניסה ישירה עם פרטים שדלפו / Password Spraying
- ◀ ⚠ רק בתוך ה-Scope

תת-דומיינים (Subdomains)

- ◀ הרחבה של הדומיין: `dev.tesla.com`
- ◀ חושפים מערכות נסתרות (dev/test)
- ◀ מרחיבים את משטח התקיפה
- ◀ כלים: **Sublist3r**, Amass, crt.sh

זיהוי טכנולוגיות האתר

builtwith.com — פירוט מלא של ה-Tech Stack ◀

Wappalyzer — תוסף מהיר ◀

whatweb — משורת הפקודה ◀

מחפשים: שרת+גרסה, CMS, Framework ◀

Google Dorking

site: — הגבלה לדומיין ◀

filetype: — סוג קובץ ◀

inurl: / intitle: — כותרת / כתובת ◀

intext: — טקסט בדף · - החרגה ◀

GHDB 📢 — מאגר Dorks מוכנים ◀

Burp Suite — היכרות

◀ **Proxy** בין הדפדפן לשרת

◀ לראות ולערוך כל Request / Response

◀ הגדרה: Proxy ← Firefox 127.0.0.1:8080

◀ התקנת תעודת CA ל-HTTPS

סיכום מודול 4

- ◀ פסיבי לפני אקטיבי; אמת יעד וקרא Scope
- ◀ OSINT על מיילים + דלף מידע = פרטי גישה
- ◀ Sublist3r מרחיב משטח תקיפה
- ◀ builtwith ממקד חולשות; Proxy = Burp מרכזי
- ◀ **תרגול:** Sublist3r + builtwith + 3 Dorks